



AWS Solution Architect

(UNIT-3:Networking & Content Delivery)

Dr. Shagun Sharma

Assistant Professor

School of Computing Science and Engineering

shagunsharma@vitbhopal.ac.in

Amazon API Gateway



❖ Introduction to API

- API stands for Application Program Interface. An **API Gateway** is a management tool that acts as an interface between users and microservices. The **Amazon API Gateway** is an **AWS service** that allows users to create, publish, secure, maintain and monitor APIs at any scale.
- You can create APIs in your client application and can also make them available to third-party developers.
- It is serverless. It supports **HTTP, WebSocket, and REST APIs**. API Gateway is a type of server that provides the service of API which is used to customize each client.
- The Netflix API Gateway is the most popular example of API Gateway.
- Many e-commerce site uses an API gateway to provide the endpoint for retrieving the details of all products from mobile clients with only a single request. So, This invokes many different services like the proper information of product, and product reviews and then combines the results.

Amazon API Gateway



◆ What is Amazon API Gateway?

- Amazon API Gateway is a fully managed service by **Amazon Web Services** that enables developers to create, publish, monitor, and secure APIs at any scale.
- It acts as a gateway between client applications and backend services, handling requests and routing them to the appropriate service.
- It simplifies API management, reduces infrastructure complexity, and scales automatically to meet the demand.
- Whether you're creating RESTful APIs, WebSocket APIs, or handling serverless applications, AWS API Gateway supports a wide range of use cases with flexible, cost-effective solutions.

Amazon API Gateway



◆ Key Features of Amazon API Gateway

- 1. Traffic Management:** API Gateway provides robust traffic management capabilities, such as load balancing, request throttling, and caching. These features ensure that your API performs optimally, even under heavy traffic.
- 2. Security Features:** With IAM roles, custom authorizers, and Cognito integration, AWS API Gateway helps secure your APIs by offering features like authentication, authorization, and access control.
- 3. Version Management:** API Gateway allows you to manage different versions of your API, ensuring that clients using different versions get the correct functionality and updates.
- 4. Scalability:** AWS API Gateway scales automatically to accommodate any level of traffic, ensuring that your API can handle sudden surges or high-volume requests without downtime.
- 5. Monitoring and Analytics:** Amazon CloudWatch is integrated into API Gateway, allowing you to monitor API performance and track request logs. This helps you keep an eye on health and diagnose issues efficiently.

Amazon API Gateway



◆ How Amazon API Gateway Works?

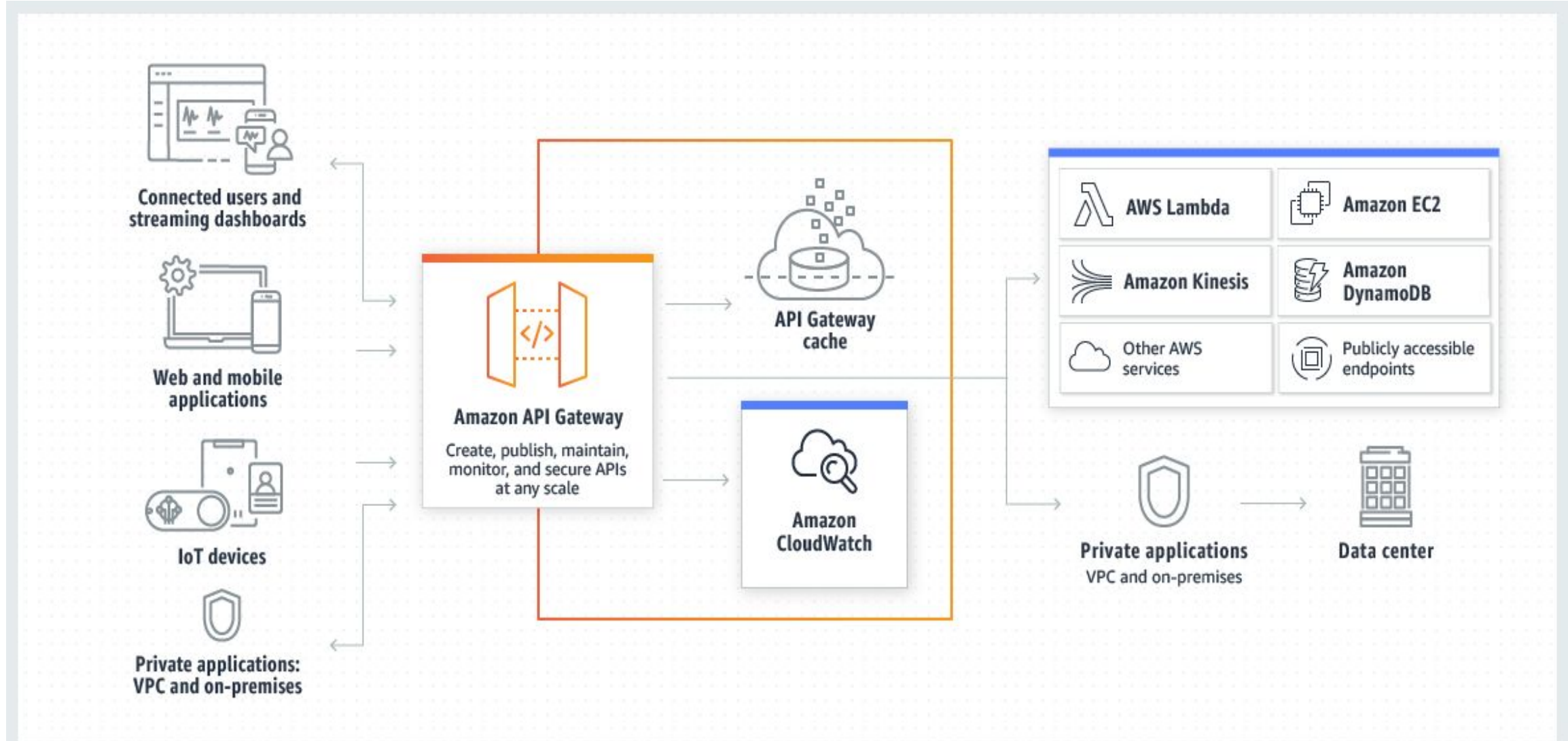
Amazon API Gateway acts as an interface between client applications and backend services. When a client sends a request, the API Gateway routes it to the appropriate backend service based on the API configuration. Once the backend processes the request, the service sends a response back to the API Gateway, which then passes it to the client.

A simplified flow of API gateway can be represented as :

Client Request → API Gateway → Backend Service (AWS Lambda, EC2, etc.) → Response → API Gateway → Client

Amazon API Gateway

This architecture minimizes client-side complexity while centralizing API management.



Amazon API Gateway



◆ What types of APIs does Amazon API Gateway support?

AWS API Gateway supports different API types to cater to various use cases:

1. **REST APIs Private and Public:** These are the traditional web APIs you might be familiar with. They use standard web requests (like GET, POST, DELETE) to interact with resources.
2. **SOAP APIs:** Simple Object Access Protocol(SOAP) APIs use a structured XML format for messages, like a very detailed and formal letter with specific sections for sender, recipient, and content.
3. **GraphQL APIs:** GraphQL is an open-source data query and manipulation language for APIs and a runtime for fulfilling queries with existing data. GraphQL APIs offer three primary types of operations for interacting with data: Queries, Mutations, and Subscription. Queries are used to fetch or read data from the server. Mutations are used to modify data on the server. and Subscription is used to enable real-time updates and allow clients to listen for changes to specific data on the server
4. **WebSocket APIs:** Once you establish the connection (make the "call"), it stays open. Both you and the server can talk to each other freely and instantly, sending messages back and forth without having to hang up and call again for every piece of information.

AWS CloudFront: CDN Cloud Service



❖ Introduction

- AWS CloudFront is a fast delivery service that brings website and app content closer to users by storing copies in multiple "edge" locations around the world. Instead of a user's request having to travel all the way to the original server, CloudFront sends the content from the nearest edge location, resulting in faster loading times and better performance. Think of it like having many local warehouses for your content instead of just one central one.
- AWS CloudFront is like a super-fast delivery service for your website's content. It's a Content Delivery Network (CDN) that helps websites, videos, APIs, and apps load faster by storing copies of content in multiple locations around the world. When someone visits your site, CloudFront delivers the content from the nearest location, reducing wait times and improving performance.
- AWS CloudFront makes it possible for companies to swiftly and effectively distribute content to users worldwide, including static or dynamic data, videos, images, and APIs.
- CloudFront caches copies of your content in strategically located servers known as edge locations. When a user makes a request for your content, CloudFront delivers it from the nearest edge location, reducing latency and improving load times. This ensures low-latency delivery, high transfer speeds, and an optimized user experience.
- CloudFront is an essential component of the AWS ecosystem since it easily integrates with other AWS services like [Amazon S3](#), [EC2](#), [Lambda](#)@Edge, and API Gateway.

AWS CloudFront: CDN Cloud Service

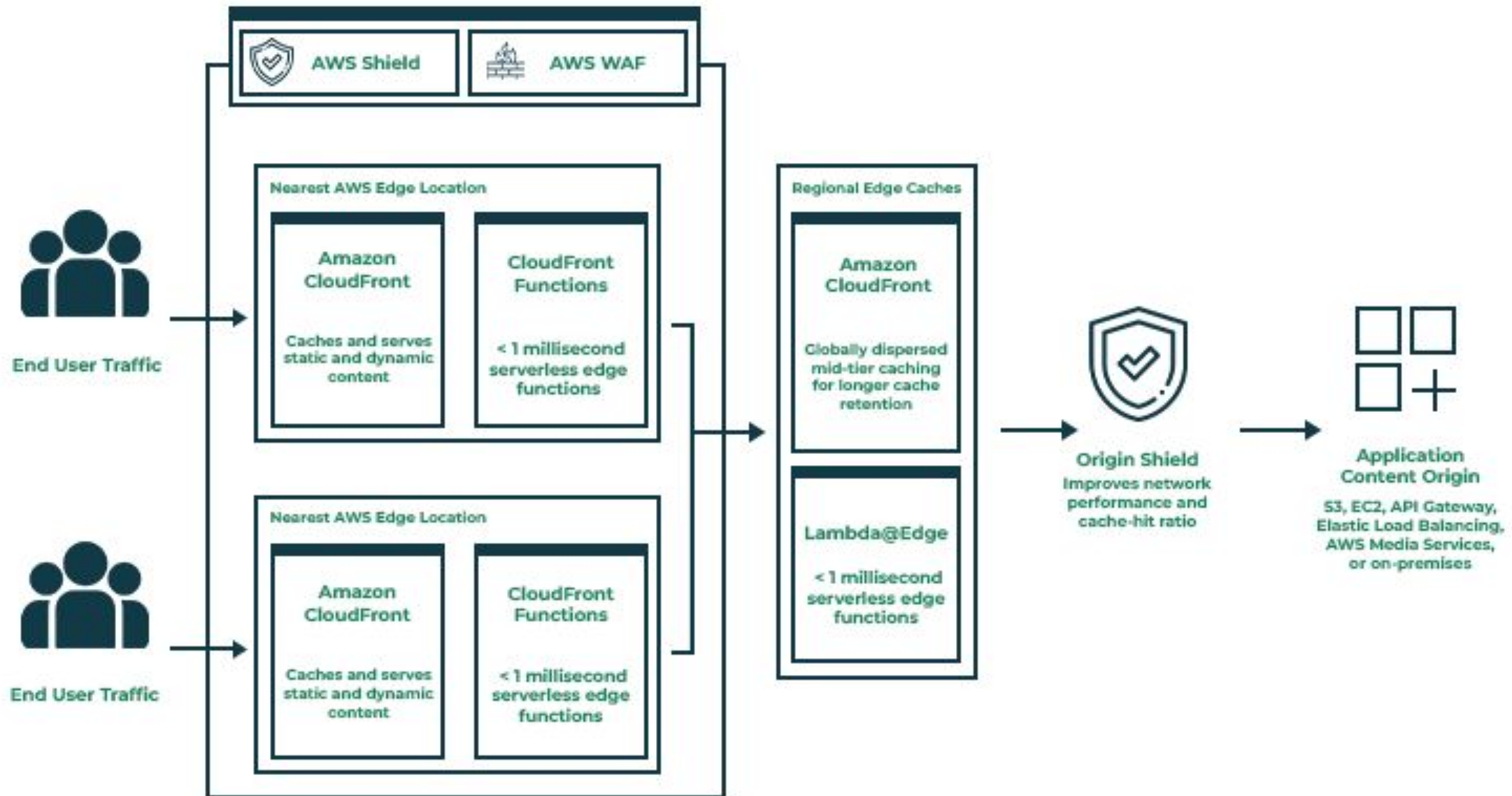


◆ Key Components of AWS CloudFront

The following are the Key Components of AWS CloudFront:

1. **Edge Locations:** Data centers worldwide that cache content closer to users.
2. **Origin Server:** The main server hosting the original content (e.g., S3 bucket, EC2 instance, or on-premises server).
3. **Distribution:** The configuration for delivering content via CloudFront.
 - **Web Distribution** (for websites, APIs, and static/dynamic content)
 - **RTMP Distribution** (for streaming media, though deprecated)
4. **Cache Behaviours:** Defines caching rules (TTL, cookies, query strings, etc.).
5. **Signed URLs & Signed Cookies:** Secure access for private content.
6. **Lambda@Edge:** Runs custom logic at edge locations (e.g., modifying HTTP headers, URL rewrites).

AWS CloudFront: CDN Cloud Service



AWS CloudFront: CDN Cloud Service



◆ How does AWS CloudFront work

Step 1: User Requests Content - A user asks for something like an image, video, or webpage from a website or app.

Step 2: DNS Routes the Request - The [DNS \(Domain Name System\)](#) finds the closest CloudFront server and sends the request there for faster delivery.

Step 3: CloudFront Checks for Cached Content - CloudFront checks if the requested content is already stored in the nearest server:

- **If it's stored:** CloudFront gives the content right away.
- **If not stored:** CloudFront sends the request to the main server to get the content.

Step 4: Content Comes from the Origin Server - The main server (like **Amazon S3, EC2**, or your own server) sends the requested content to the nearest CloudFront server.

Step 5: CloudFront Caches the Content - CloudFront saves the content in the server so that it can be used again in the future, making the system faster.

AWS CloudFront: CDN Cloud Service



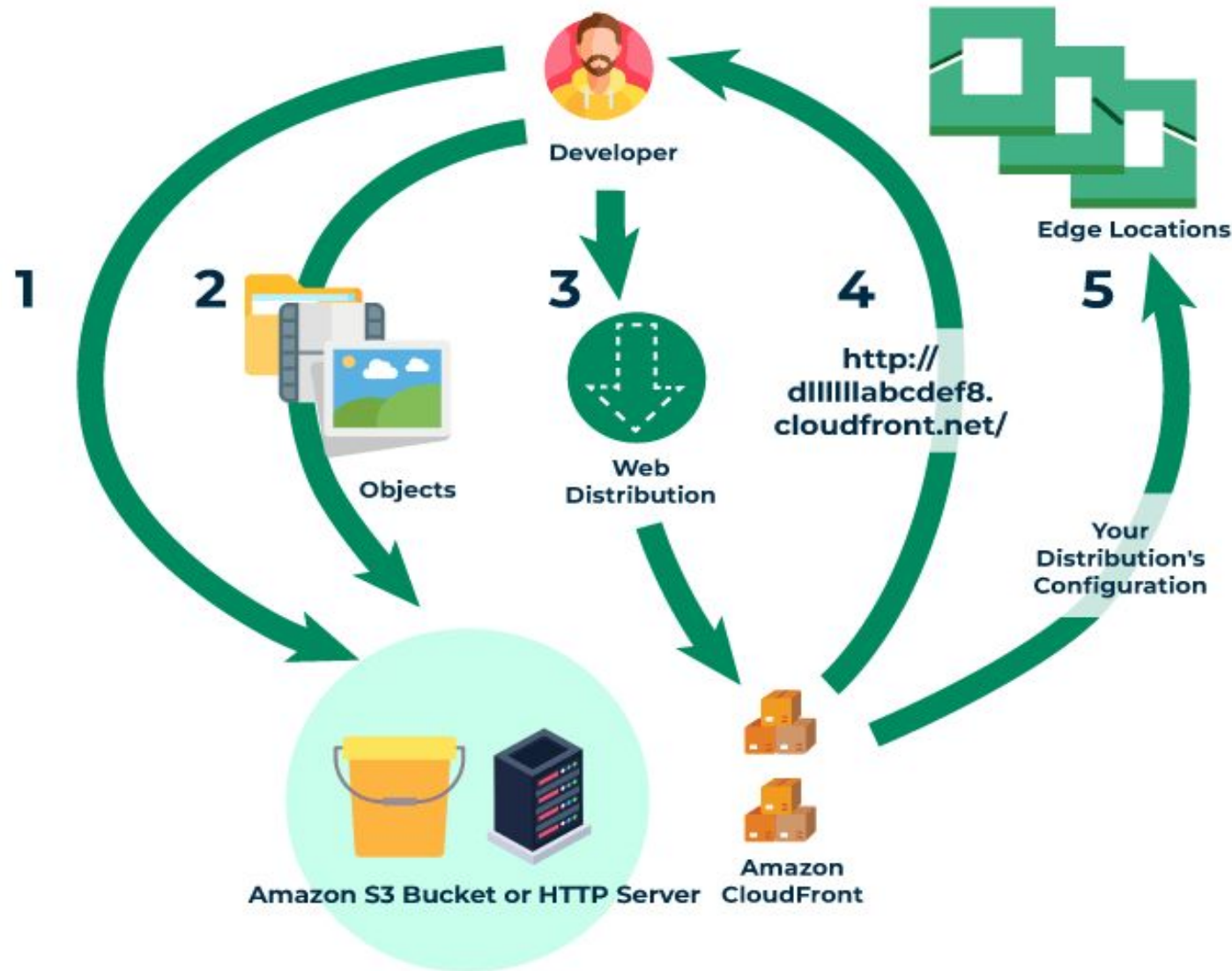
◆ How does AWS CloudFront work

Step 6: CloudFront Delivers Content - CloudFront sends the content to the user from the nearest server, which makes it load faster because it's closer to the user.

Step 7: Future Requests - For future requests, CloudFront gives the content directly from its cache, making the process even quicker.

Step 8: Cache Update (When Needed) - CloudFront checks with the main server regularly to see if the content has been updated. If it has, CloudFront fetches the new version and updates the cache for future use.

AWS CloudFront: CDN Cloud Service



AWS CloudFront: CDN Cloud Service



◆ Key Features of AWS CloudFront

1. **Faster Content Delivery Across the Globe:** CloudFront stores copies of your content in multiple locations worldwide. When someone requests it, they get it from the nearest location, making your website or app load much faster.
2. **Works Seamlessly with AWS Services:** You can easily connect CloudFront with S3 (for storing files), EC2 (for hosting websites), API Gateway (for APIs), Route 53 (for domains), AWS WAF (for security), and ELB (for load balancing).
3. **Built-in Security & Protection Against Attacks:** CloudFront helps block DDoS attacks and malicious traffic using AWS Shield and AWS WAF. It also supports secure HTTPS connections and access control to protect your content.
4. **Efficient Caching for Both Static & Dynamic Content**
 - **Static content** like images, JavaScript, and CSS files are stored and delivered instantly.
 - **Dynamic content** like APIs or personalized pages are optimized to load faster without unnecessary delays.
5. **Budget-Friendly & Scales with Your Needs:** You only pay for what you use, and AWS offers 1 TB of free data transfer per month in its Free Tier.
6. **Super Low Latency & High Performance :** CloudFront **automatically finds the fastest route** to deliver content, ensuring smooth user experiences with minimal delays.

AWS CloudFront: CDN Cloud Service



◆ Companies using AWS CloudFront

Company	Use Case
United States Department of Defence	Secure content distribution across its extensive network.
Walmart	Enhances performance and reliability of its online retail platform.
Amazon	Accelerates content delivery for its e-commerce operations.
Netflix	Streams high-quality video content globally with low latency.
Disney	Supports Disney+ with scalable and secure content delivery.
BMW	Enhances vehicle connectivity and digital services via CloudFront.
McDonald's	Optimizes customer experience with machine learning and analytics.
Capital One	Supports banking services with high-security cloud solutions.

AWS Direct Connect

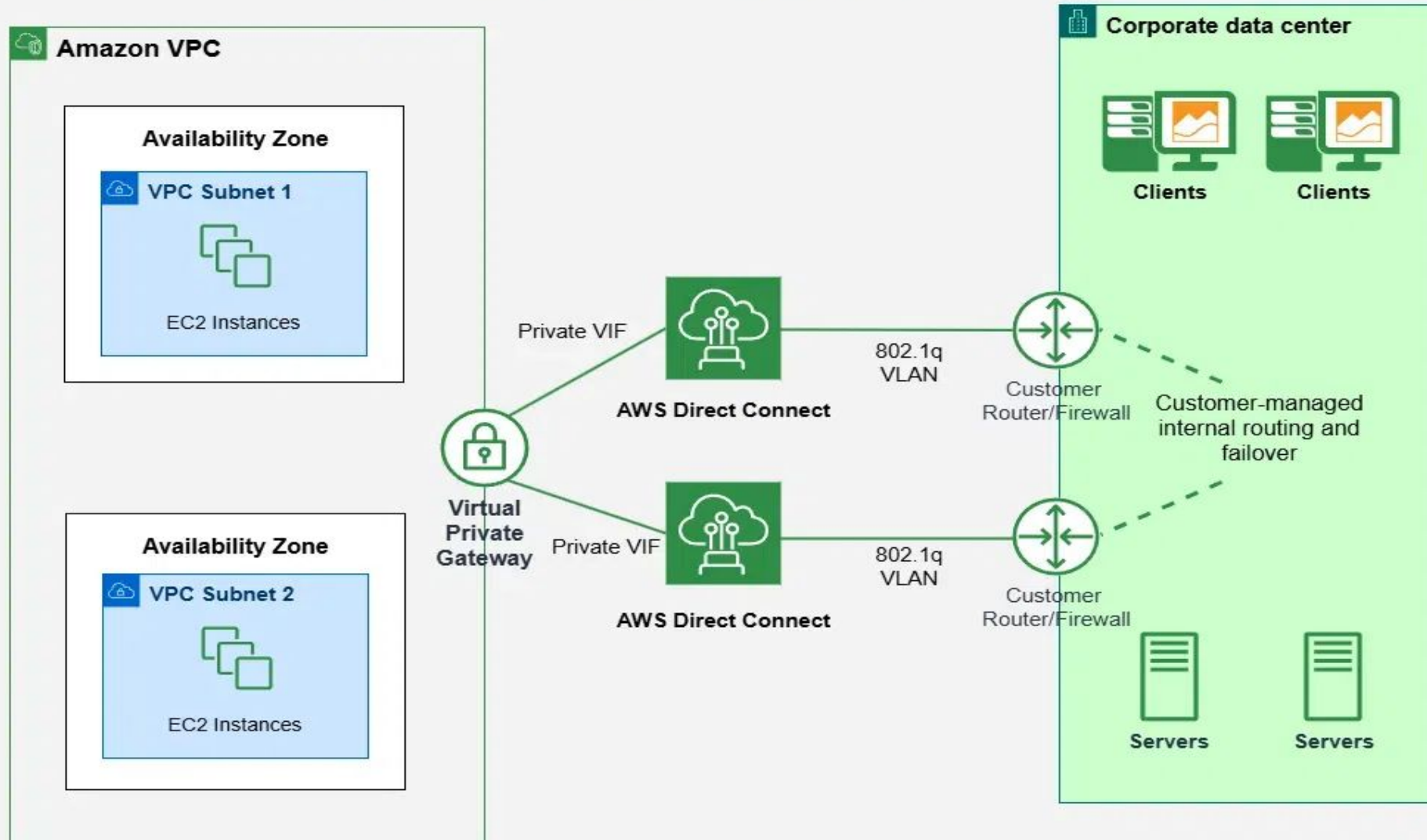


❖ Introduction

- AWS Direct Connect is like building a private, high-speed, and secure internet cable directly from your office to the Amazon Web Services (AWS) cloud, completely bypassing the public internet. Instead of sharing a road with everyone else (the internet), you get your own dedicated lane, which means a more consistent, reliable, and faster connection with better performance. This is crucial for tasks that require predictable speeds and security, like moving large amounts of data or running business-critical applications.
- **AWS Direct Connect** is a cloud service that provides businesses with a secure, high-bandwidth, and low-latency connection from their on-premises infrastructure directly to AWS services. By bypassing the public internet, it ensures private, more reliable, and secure data transfer. This direct connection is typically set up using fiber-optic cables or Ethernet links to AWS Direct Connect locations, ensuring better network performance and security for mission-critical applications.

AWS Direct Connect

What is AWS Direct Connect?



AWS Direct Connect



◆ AWS Direct Connect Working

AWS Direct Connect works by creating a dedicated physical connection between your on-premises network and an AWS Location. This connection uses fiber and ethernet cables to link your network directly to an AWS router, avoiding the public internet. Once the physical connection is in place, a **virtual interface (VIF)** is set up to create a secure connection between your network and AWS, allowing you to access AWS services easily and securely.

AWS Direct Connect



◆ Setting Up AWS Direct Connect

- **Step 1: Connect an AWS Direct Connect Location** - Select an AWS Direct Connect location that is closest to your infrastructure. AWS provides a list of available locations on the Direct Connect portal.
- **Step 2: Select a Network Service Provider** - Pick a network service provider from the AWS Direct Connect Partners page. This provider will bridge the connection between your on-premises network and AWS. When choosing, consider factors like bandwidth and location.
- **Step 3: Provision a Dedicated Network Connection** - Provision a dedicated network connection between your infrastructure and the chosen service provider's location. This physical link ensures the high performance and reliability of your AWS connection.
- **Step 4: Configure the Virtual Interface** - Log in to the **AWS Management Console** and navigate to **Direct Connect**. Create a virtual interface by providing the **VLAN ID**, routing, and other configuration details. Once completed, your AWS Direct connect connection will be ready to access AWS service services such as **Amazon VPC** and **Storage Services**.

AWS Management Console -> Direct Connect -> Create virtual interface

AWS Direct Connect



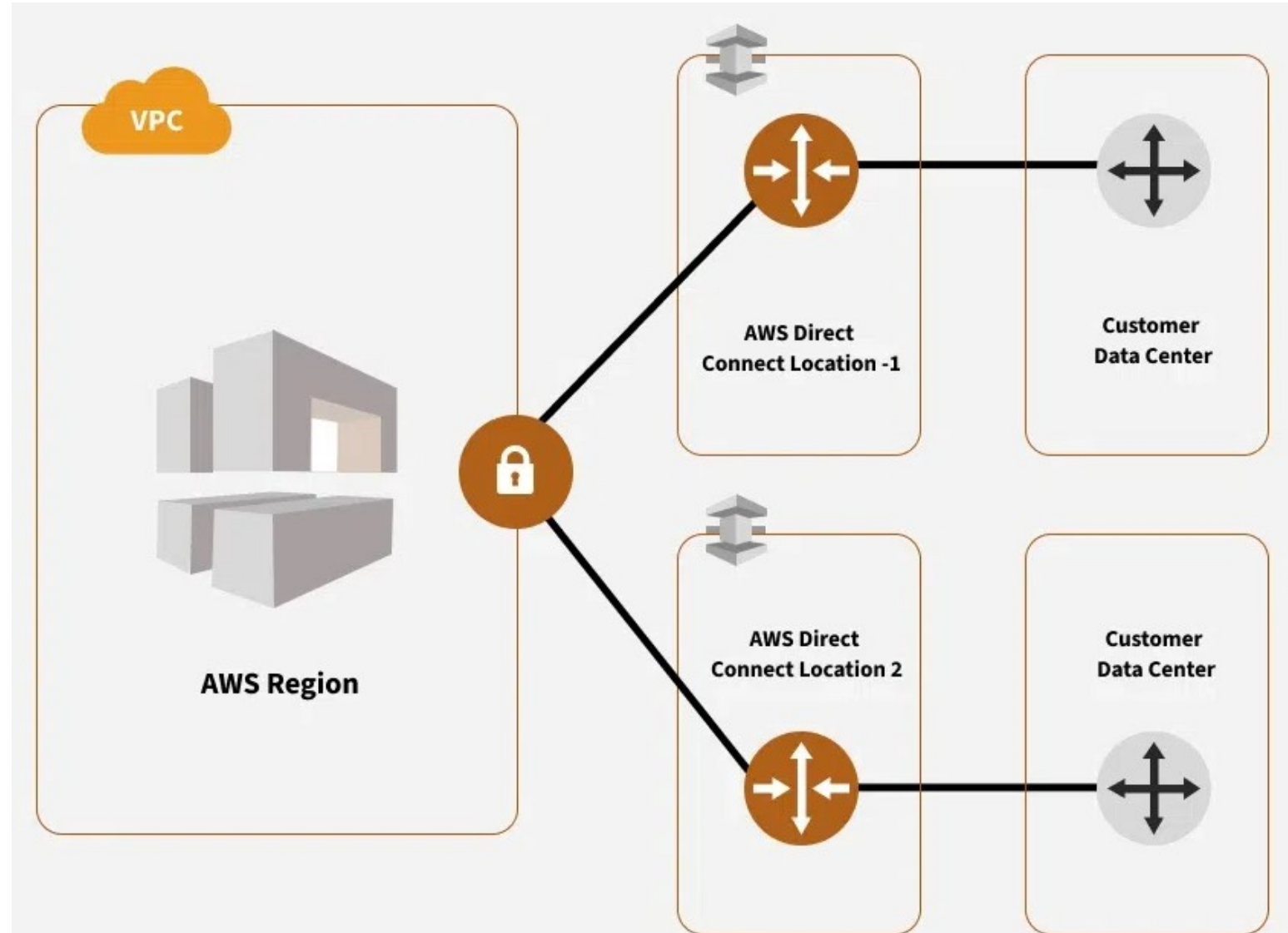
◆ Benefits of Using AWS Direct Connect

- It provides a connection with high bandwidth and low latency, hence reliability and performance are increased.
- Since a dedicated private connection is established completely bypassing the public internet hence adds to the security of your connection.
- Data transfer over AWS Direct Connect is very cost-effective as compared to using the typical public network.

AWS Direct Connect

❖ Use Cases of AWS Direct Connect

In the accompanying image, you can see how AWS Direct Connect enables a secure private connection between customer data centers and AWS. Two Direct Connect locations are set up to ensure high availability and redundancy. This configuration can support mission-critical workloads and provide continuity even if one connection experiences downtime. Each Direct Connect location connects back to the AWS Region's Virtual Private Cloud (VPC) where AWS resources can be directly accessed. This setup highlights the flexibility and reliability of AWS Direct Connect for businesses that require a constant and private connection to their AWS environment enhancing performance and security across multiple use cases.



AWS Direct Connect



◆ Difference Between AWS Direct Connect vs Site to Site VPN

Attribute	AWS Direct Connect	AWS Site-to-Site VPN
Network	Provides a dedicated, private network connection that bypasses the public internet.	Utilizes an encrypted tunnel over the public internet for connectivity.
Time to Establish	Typically takes longer to set up, as it requires physical connection setup and configuration.	Faster to set up, as it only involves configuration on both ends with no physical setup required.
Pricing	Higher cost due to dedicated infrastructure and setup requirements. Suitable for consistent, high-bandwidth use cases.	Generally more cost-effective, as it uses an existing internet connection, making it ideal for lower-budget or intermittent use.
Security	Offers a private, secure connection that doesn't go through the public internet, enhancing data security and reducing exposure risks.	Relies on encryption over the public internet, which is secure but may have potential exposure risks compared to a fully private connection.

AWS Direct Connect



◆ Pricing of AWS Direct Connect

There is no minimum setup fee for AWS Direct Connect, you have to pay for what you use. **Pricing is based on the following factors:**

- 1. Capacity:** It is the maximum rate at which can be transferred through the network, capacity of a connection is measured in megabits per second(Mbps) or gigabits per second(Gbps).
- 2. Port hours:** It measures the time for which a port is allocated for use with AWS, even when do transfer is happening at that time you are charged for port hours, Port hours depend on two factors namely, dedicated connection or hosted connection.
 - **Dedicated connections:** physical connections from your premises port to the AWS network port. These are billed as long as they are allocated for use, you can request for dedicated connection through the AWS Direct Connect section of the AWS Management Console.
 - **Hosted connections:** logical and you can request for hosted connection by directly contacting your Delivery Partner.
- 3. Data transfer out (DTO):** It refers to the total traffic out of the AWS from your network and is charged per gigabyte (GB).
- 4. Data Transfer In (DTI):** Just opposite of the DTO, it is the total traffic received in the network from outside the AWS.

AWS Networking and Content

Delivery Introduction



Amazon Web Services (AWS) provides a comprehensive range of networking and content delivery services to enable secure, high-performance, and reliable cloud solutions. These services help organizations connect, manage, protect, and deliver applications and content globally.

◆ Key AWS Networking and Content Delivery Components

- **Amazon VPC (Virtual Private Cloud):** Create isolated, customizable cloud networks for your AWS resources, enabling fine-grained control over IP addressing, subnets, and security settings.
- **AWS Transit Gateway:** Acts as a central hub to connect multiple VPCs and on-premises networks, simplifying network architecture and management.
- **AWS PrivateLink:** Securely connects VPCs to supported AWS services, SaaS vendors, or other VPCs, without exposing traffic to the public internet.
- **AWS Direct Connect:** Establishes dedicated, high-bandwidth private connections from on-premises data centers to AWS, providing lower latency and stable network performance.
- **AWS VPN:** Provides encrypted tunnels for connecting on-premises resources to VPCs, supporting both site-to-site and client-to-site access.

AWS Networking and Content Delivery



Cloud networking from AWS

NETWORKING SERVICES FOR EVERY APPLICATION AND WORKLOAD



Networking foundations

Amazon VPC
AWS Transit Gateway
AWS PrivateLink

Global & hybrid connectivity

AWS Direct Connect
AWS Direct Connect SiteLink
AWS Cloud WAN
AWS Site to Site VPN

Edge networking & content delivery

AWS CloudFront
AWS Global Accelerator
AWS Route 53

Application Networking

Elastic Load Balancing
Amazon VPC Lattice

Network security and remote access

AWS Network Firewall
AWS Verified Access
AWS Client VPN

←..... AWS **Global Network Infrastructure**, **silicon** innovation, and centralized **network operations**→

AWS Networking and Content Delivery



◆ Key AWS Networking and Content Delivery Components

- **Amazon Route 53:** A highly available Domain Name System (DNS) web service that translates domain names into IP addresses and directs end-user requests to AWS or external resources. Advanced routing options like latency-based and geo DNS help optimize user access.
- **Elastic Load Balancing (ELB):** Distributes incoming application or network traffic across multiple targets (e.g., EC2 instances), automatically scaling in response to demand and improving application resilience.
- **AWS Global Accelerator:** Uses AWS's global network to optimize the path and availability of internet traffic to distributed applications, improving performance for users worldwide.
- **Amazon CloudFront:** AWS's global Content Delivery Network (CDN) service that delivers websites, APIs, video, and other content to users with low latency by caching data at hundreds of edge locations around the world. It integrates with security services like AWS Shield and WAF.
- **AWS App Mesh and Cloud Map:** Provide service discovery and mesh networking for microservices-based architectures for improved monitoring and traffic control.

AWS Networking and Content Delivery



◆ How AWS Networking and Content Delivery Work

1. Network Foundations: Start with an Amazon VPC—your private, isolated cloud network. You can extend it using Transit Gateway, Direct Connect, VPN, and PrivateLink, tailoring connectivity to your hybrid cloud needs.
2. Traffic Routing and Management: Use Route 53 for domain management and advanced routing. Leverage Elastic Load Balancing to distribute workloads and optimize utilization.
3. Global Performance and Security: AWS Global Accelerator and CloudFront accelerate content delivery and application access globally, using AWS's robust infrastructure for speed, security, and reliability.
4. Content Delivery: CloudFront caches your content at edge locations, serving users from the closest location to minimize latency and bandwidth costs. Dynamic content delivery is enhanced with intelligent routing and edge computing capabilities.

AWS Networking and Content Delivery



◆ Benefits

- **Security:** End-to-end encryption, access control, firewalls, and monitoring ensure data confidentiality and integrity.
- **Scalability:** Services automatically adjust capacity and routing in response to changing traffic and application needs.
- **Performance:** Globally distributed networks and edge locations reduce latency and improve load times for users anywhere in the world.
- **Reliability:** Multi-region infrastructure and advanced routing protect against outages and ensure high availability.

AWS Networking and Content Delivery



◆ Real-Life Applications of AWS Networking and Content Delivery

- **Streaming Platforms (e.g., Hulu, Amazon Prime Video):** These platforms use Amazon CloudFront, AWS's content delivery network (CDN), to deliver video on demand to millions of viewers, ensuring high-quality live and on-demand streaming with minimal buffering and latency.
- **Global Game Delivery (e.g., King, Rovio, Supercell):** Gaming companies distribute static and dynamic game assets using CloudFront, supporting millions of concurrent users and providing seamless gameplay across international markets.
- **Expedia:** Uses AWS for robust, secure, and highly available infrastructure, ensuring customers receive consistently fast and uninterrupted booking experiences regardless of traffic spikes.
- **Novartis:** Leveraging AWS networking and storage services, Novartis processes and stores large volumes of medical data securely, supports global research teams, and provides reliable digital health platforms for patients.
- **Supply Chain Optimization:** Businesses use AWS networking to track shipments in real time, analyze logistics data for route optimization, and ensure reliable worldwide connectivity.

Amazon VPC (Virtual Private Cloud)



◆ Introduction

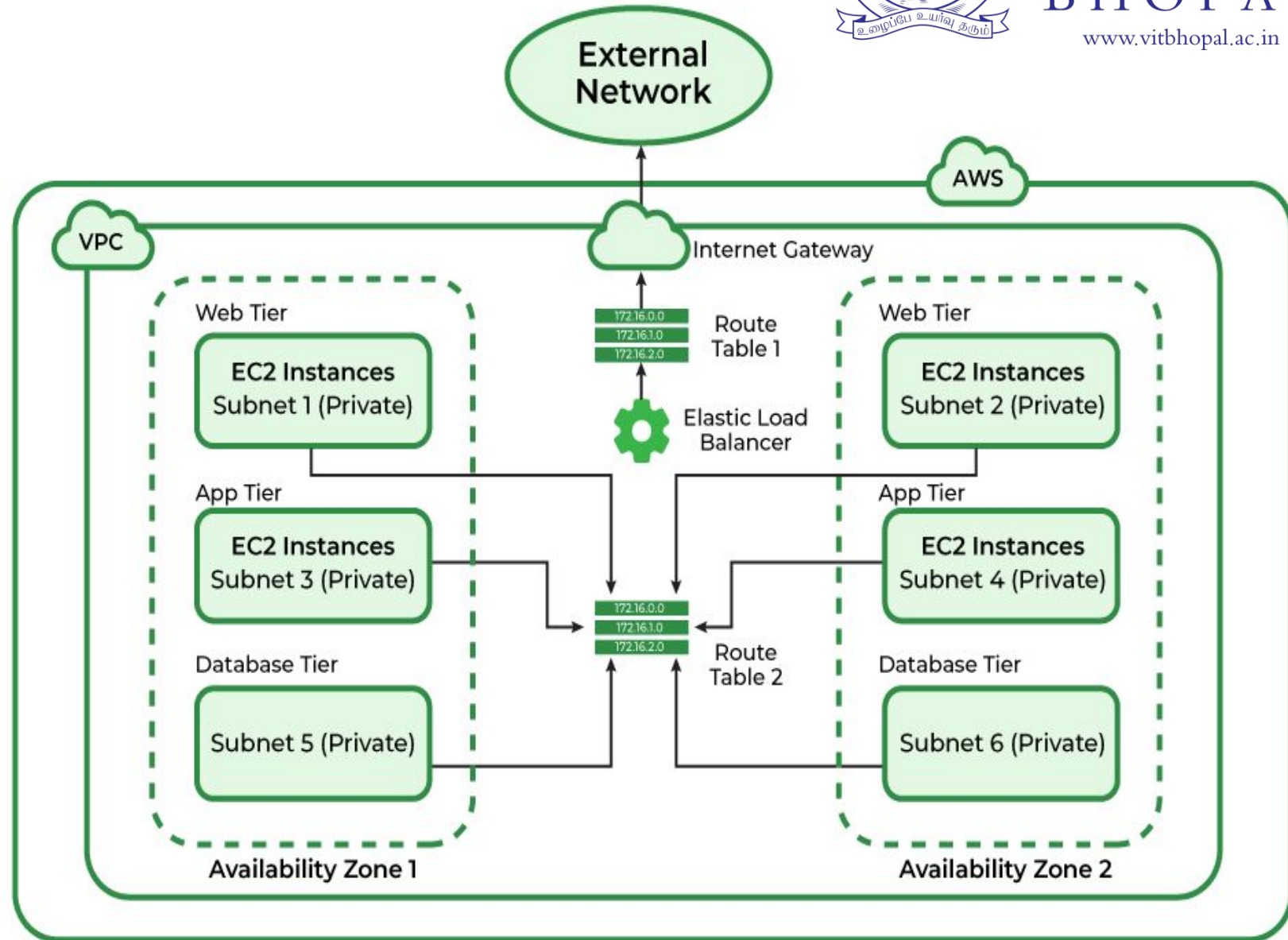
- Amazon VPC is your own private, secure "network" within the larger AWS cloud. It allows you to launch your cloud resources (like servers and databases) in a logically isolated virtual network that you control, giving you the same benefits of a traditional data center but with the scalability of the cloud. You have complete control over your IP address range, subnets, and how your resources are connected to the internet or your own data center.
- We can place the necessary resources and manage access to those resources in the VPC, a private area of Amazon that we control.
- A default "VPC" will be generated when we register an [AWS account](#), allowing us to manage the virtual networking environment, the [IP address](#), the construction of subnets, route tables, and gateways.

Amazon VPC (Virtual Private Cloud)



Amazon VPC (Virtual Private Cloud) Architecture

The basic architecture of a properly functioning VPC consists of many distinct services such as Gateway, Load Balancer, Subnets, etc. Altogether, these resources are clubbed under a VPC to create an isolated virtual environment. Along with these services, there are also security checks on multiple levels. It is initially divided into subnets, connected with each other via route tables along with a load balancer.



Amazon VPC (Virtual Private Cloud)



◆ Amazon VPC (Virtual Private Cloud) Components

- **VPC:** You can launch AWS resources into a defined virtual network using Amazon Virtual Private Cloud (Amazon VPC). With the advantages of utilizing the scalable infrastructure of AWS, this virtual network closely mimics a conventional network that you would operate in your own data center. /16 user-defined address space maximum (65,536 addresses)
- **Subnets:** Amazon subnets are like smaller sections of your virtual private cloud (VPC) that help you organize and isolate resources, similar to how you might divide an office building into different departments. For example, you can create a public subnet for your website's web servers, which needs to be accessed from the internet, and a separate private subnet for your database, which should not be directly accessible from the outside.
- **Route Tables:** An Amazon Route Table is like a GPS or a set of traffic rules for your private cloud network (VPC) in AWS. It contains a list of rules (called routes) that determine exactly where network traffic from your resources (like a web server) should be sent to reach its final destination, whether that destination is within the same network, the internet, or a different connected network.

Amazon VPC (Virtual Private Cloud)



◆ Amazon VPC (Virtual Private Cloud) Components

- **Network Access Control Lists:** In layman's terms, an Amazon Network Access Control List (NACL) is like a security guard for a building's different floors, controlling which groups of people (traffic) can enter or leave each floor (subnet). It has a list of rules that either allow or deny access, acting as a firewall for the network traffic moving in and out of a subnet. For example, you might use a NACL to block all incoming traffic from a specific IP address or only allow outbound connections for a web server on a specific port.
- **Internet Gateway(IGW):** In simple terms, an Amazon Internet Gateway (IGW) acts as the main entrance and exit gate for your private cloud network (VPC) to communicate with the public internet. It is a horizontally scaled, highly available AWS component that allows resources with public IP addresses in your public subnets to send and receive traffic from the internet.
- **Network Address Translation (NAT):** Amazon Network Address Translation (NAT) Gateway is a managed AWS service that allows resources (like servers) in a private, secure part of your cloud network to connect to the internet, without allowing anything from the internet to initiate a connection with them.

Amazon VPC (Virtual Private Cloud)



❖ Amazon VPC Benefits

- **Advanced Security and Isolation:** Provides logical network isolation, security groups, and network ACLs for precise inbound/outbound filtering at subnet and instance levels. Enables private connectivity to AWS services without exposing resources to the public internet.
- **Flexibility and Control:** Customize your IP address range, networking topology, routing tables, and subnets to suit your workload requirements.
- **Seamless Scalability:** Easily scale resources up or down, deploy across multiple availability zones, and take advantage of auto-scaling without hardware constraints.
- **Integrated Monitoring and Management:** Use VPC flow logs for detailed visibility into traffic, Network Access Analyzer for compliance, and monitoring tools for infrastructure health.
- **Cost Savings:** Eliminate the need for costly on-premises hardware, benefit from pay-as-you-go pricing, and automate routine network management tasks.
- **High Availability and Disaster Recovery:** Design environments for fault tolerance using multi-AZ deployments, robust routing, and NAT gateways.
- **Easy Integration:** Integrate seamlessly with AWS services (EC2, RDS, S3, Lambda) and third-party solutions, supporting diverse workloads within the same virtual network.

Amazon VPC (Virtual Private Cloud)



◆ Use cases of Amazon VPC

- Using VPC, you can host a public-facing website, a single-tier basic web application, or just a plain old website.
- The connectivity between our web servers, application servers, and database can be limited by VPC with the help of VPC peering.
- By managing the inbound and outbound connections, we can restrict the incoming and outgoing security of our application.

Amazon VPC Example



◆ Example

- A Virtual Private Cloud (VPC) is like having your own private, secure plot of land to build your network on, but inside a massive, shared public city (the cloud provider's infrastructure). It gives you an isolated environment where you have full control over your resources and how they communicate.

The Gated Community

Imagine the public cloud (like AWS, Azure, or Google Cloud) is a massive city with endless resources. A VPC is your own gated community within that city.

- **The VPC (The Gated Community):** This is your isolated space. The main cloud provider owns and maintains the physical land and infrastructure (roads, power grid), but you decide the layout and rules within your community's borders.

Amazon VPC Example



◆ Example

The Gated Community

- **Subnets (Neighborhoods/Streets):** Inside your community, you divide the land into different areas (subnets).

Public Subnets: These are the streets near the main gate that have direct access to the internet (e.g., your website's web servers, which need to be publicly reachable).

Private Subnets: These are the quieter, internal streets with no direct internet access (e.g., where you'd put sensitive databases or application servers).

- **Internet Gateway (The Main Gate):** This is the main, controlled entry and exit point for all traffic coming in from or going out to the rest of the city (the public internet).

Amazon VPC Example



◆ Example

The Gated Community

- **NAT Gateway (Network Address Translation) (The Back Door/Delivery Entrance):** This allows resources in the private subnets (e.g., your database server needing to download software updates) to go out to the internet, but it prevents unsolicited traffic from the internet from coming in directly.

- **Security Groups & Network ACLs (Security Guards & Fences):**

Network ACLs are like the perimeter fences and street patrols, controlling traffic flow for an entire street (subnet).

Security Groups are like personal guards for each house (server), deciding exactly who can enter or leave that specific building.

- **Route Tables (Road Signs/GPS):** These are the rules that tell network traffic how to get from one place to another within your community or how to reach the outside world.

Amazon VPC Example



◆ Example2

- **Isolation (Your Door Lock):** The most important feature is isolation. Your VPC is logically separated from all other customers' VPCs. No one else can access your data or applications unless you specifically allow them to.
- **Subnets (Rooms in Your Apartment):** You can divide your apartment into different rooms, or subnets.

Public Subnet: A room with a window facing the street (the internet). You might put things here that need to be accessible to everyone, like a public website.

Private Subnet: A back room with no public access. You would keep sensitive things here, like your databases and application servers, safe from the public internet.

Amazon VPC Example



◆ Example2

- **Security Groups (NAT Gateway)(Bouncers/Doormen):** These act as a set of rules, like having a bouncer at the door of each room (subnet) or even each individual server. They check the ID of everyone trying to enter or leave and decide who is allowed based on your specific rules.
- **Route Tables (Hallway Directions):** These are like signs in your hallway that tell network traffic where to go. They direct traffic meant for the internet towards a gateway, and keep internal traffic within your private rooms.
- **Internet Gateway (The Main Exit to the Street):** This is the main exit you configure that allows your public subnet to talk to the rest of the world.

AWS VPC Peering



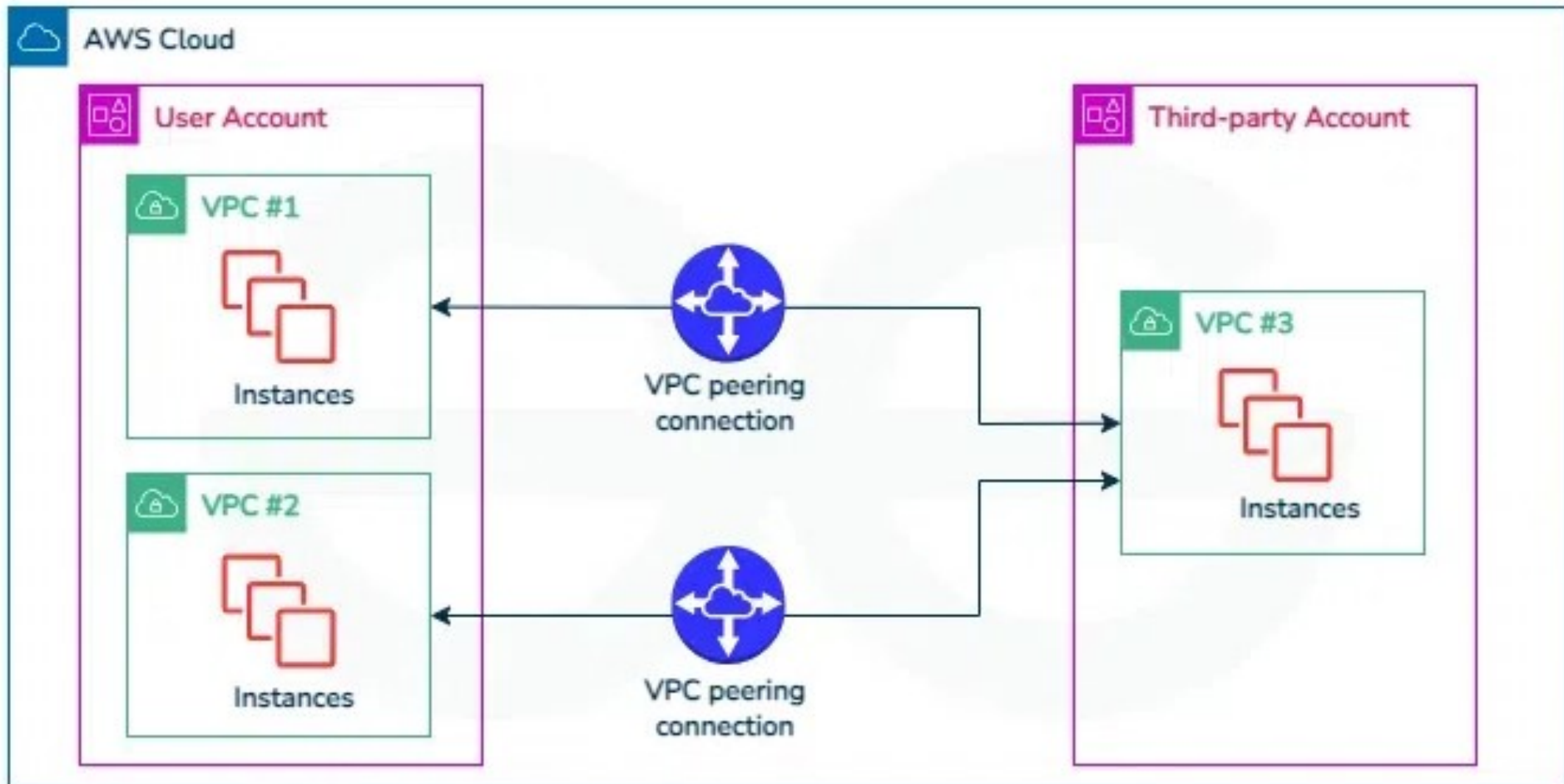
◆ Introduction

- Virtual Private Cloud Peering is known as VPC Peering. It is an AWS networking function that provides safe and direct communication between different **VPCs**. By using the VPC peering feature organizations can establish private connections that facilitate the secure and smooth transfer of resources and data across various VPCs in the AWS Cloud. By establishing communication between different environments and maintaining the integrity of each VPC environment setting, VPC peering makes network management easier.
- In the AWS ecosystem, VPC peering is an essential service for creating scalable, networked infrastructure structures. Amazon peering provides an effective way of linking Virtual Private Clouds (VPCs) and offers strong networking capabilities inside AWS. The complexities of VPC peering are addressed with an effective way of explanation. This article clarifies how to establish smooth communication across different cloud environments in AWS.

AWS VPC Peering

◆ AWS VPC Peering Architecture

The following architecture diagram illustrates on usage of VPC peering connections to connect VPCs in your account with a VPC in the third-party account.



AWS VPC Peering



◆ AWS VPC Peering Connection Lifecycle

The lifecycle of AWS VPC peering connection involves with several key stages. Those are discussed as follows:

- **Initiation:** The life cycle process starts with initiating a request to peer two VPCs. This request involves specifying the VPCs to be peered and their respective settings.
- **Approval:** After the request is raised, the administrator of the receiving VPC has to accept that peering connection. This step involves both the parties to agree on the connection establishment.
- **Establishment:** Once both have approved the peering connection, the VPC peering connection is established. This enables the communication between two VPCs, if they were within the same network, i.e., allowing instances in one VPC to communicate with other VPC's instances using private IP addresses.
- **Configuration:** After once the connection is established, the administrator may ensure configuring the route tables and security groups to control the flow of the traffic between peered VPCs. These steps ensure the communication should be done in a secured manner and follow the desired network paths.

AWS VPC Peering



◆ AWS VPC Peering Connection Lifecycle

- **Utilization:** With this peered connections, the resources within the peered VPCs can communicate with each other seamlessly. This provides various use cases such as data replication, resource sharing and application integration across multiple VPCs.
- **Monitoring And Maintenance:** Administrators continuously monitor the performance and security of the VPC peering connection. They may also perform the maintenance tasks such as updating route tables or adjusting security group rules as needed to optimize the connection's performance and ensuring its reliability.
- **Termination (Optional):** If need arises, the administrators can look for terminating the VPC peering connection. This effectively serves as the network link between the VPCs and prevents further communication between them.

AWS VPC Peering



◆ AWS VPC Peering Connection Lifecycle Example

The VPC Peering Lifecycle

Initiating/Pending Acceptance:

- **Action:** One VPC owner (the "requester") sends an invitation to connect to another VPC owner (the "accepter").
- **Status:** The connection is like a pending friend request on social media. It's sent, but not active yet. The accepter has 7 days to respond before the request automatically disappears (expires).

Failed/Rejected/Expired (The "No, thanks" scenarios):

- **Action:** If the request can't be made (e.g., the VPCs have overlapping IP addresses), it fails immediately. If the accepter owner declines the request, it's rejected. If they do nothing for 7 days, it expires.
- **Status:** The potential connection is shut down and cannot be used.

AWS VPC Peering



◆ AWS VPC Peering Connection Lifecycle Example

The VPC Peering Lifecycle

Provisioning:

- Action: The acceptor owner accepts the request.
- Status: AWS is setting up the connection behind the scenes. This stage is usually very quick and moves to the next stage.

Active (The "We're connected!" stage):

- Action: The connection is live! But wait, you still need to update the "rule books" (route tables and security groups) for both VPCs to specifically allow traffic to flow between them.
- Status: The virtual handshake is complete, and with the right rules in place, data can now flow privately and securely between the two VPCs.

AWS VPC Peering



◆ AWS VPC Peering Connection Lifecycle Example

The VPC Peering Lifecycle

Deleting/Deleted:

- Action: Either VPC owner can decide to end the connection at any time while it's active.
- Status: The connection is in the process of being deleted (deleting) or has been successfully ended (deleted). Communication stops, and resources in one VPC can no longer talk directly to resources in the other.

AWS VPC Peering



◆ Advantages of VPC Peering

The following are the advantages of VPC peering:

- **Seamless Communication:** It helps in directing and securing the connection between the VPCs. It facilitates with this in sharing of resources and data transfers.
- **Cost Efficiency:** On establishing the private network communication based VPC peering removes the need of expensive public internet data transport making cost efficiency.
- **Simplified Network Management:** VPC peering simplifies the network architecture making it easier of network management and resolving complexities associated with traditional networking.
- **Resource Access:** VPC peering provides the access to the resources in different VPCs enhancing the efficiency of organizations services across interconnected networks.

AWS VPC Peering



◆ Pricing for a VPC Peering Connection

The following tabular format discusses the pricing details of VPC Peering:

Component	Description	Cost
VPC Peering Connection	It used for establishment of VPC Peering connection	\$0.01 per GB
Data Transfer between VPCs	It used for transferring the data between VPCs	\$0.02 per GB
NAT Gateway	If it is used for data transfer	Additional fee
Data Processing	If data processing has done in VPC	Variable (Charge varies based on many parameters)
Support	It used for provding support to VPC Connection	Variable (Charge varies based on many parameters)

AWS Security and Compliance



◆ AWS Security and Compliance

- Amazon Web Services (AWS) implements a robust, multi-layered approach to security and compliance, ensuring customers can run workloads safely while meeting regulatory and industry requirements.
- AWS Security and Compliance refers to the shared responsibility model where Amazon Web Services (AWS) secures the underlying cloud infrastructure ("security of the cloud"), and the customer is responsible for securing what they build and run on the cloud ("security in the cloud"). This includes using AWS's tools and features for access control, data encryption, and network security, while adhering to relevant regulations and standards like PCI DSS, ISO, and HIPAA. AWS provides the infrastructure, security services, and compliance certifications to help customers meet their own security objectives. ((Payment Card Industry Data Security Standard), (International Organization for Standardization), (Health Insurance Portability and Accountability Act),)

AWS Security and Compliance



◆ Security

- **Shared Responsibility Model:** AWS manages the physical infrastructure, while customers are responsible for their own data, applications, operating systems, and network configuration within AWS.
- **Security Services:** AWS provides a wide range of services to help customers manage security, including:
 - **Access Control:** Services that manage user permissions and identities.
 - **Data Encryption:** Tools for encrypting data both in transit and at rest.
 - **Threat Detection:** Services like Amazon GuardDuty that continuously monitor for malicious activity.
 - **Security Posture Management:** Services like AWS Security Hub that provide a unified view of security alerts and compliance status.

AWS Security and Compliance



◆ Security

- AWS security is based on the shared responsibility model:
- **AWS's Responsibility ("Security of the Cloud")**
- **AWS manages and secures the underlying infrastructure** — physical facilities, network, hardware, virtualization layer, and foundational services.
- **Customer's Responsibility ("Security in the Cloud")**
- **Customers are responsible for configuring secure workloads** — e.g., user access management, application-level security, data classification, and encryption.

AWS Security and Compliance



◆ Compliance

- **Certifications and Audits:** AWS undergoes continuous auditing and holds a variety of certifications from independent bodies to demonstrate that its infrastructure meets stringent security standards.
- **Customer Compliance:** Customers can use AWS's compliance reports and tools to help them meet their own regulatory requirements.
- **Compliance Programs:** AWS offers programs and services that help customers align their cloud environments with specific compliance standards and provides resources like the AWS Artifact Compliance Center for accessing reports.
- **Industry-Specific Compliance:** AWS helps customers in various industries, like healthcare (HIPAA), finance, and government, meet their specific compliance needs.

AWS Security and Compliance



❖ Key AWS Security Components

- **Identity and Access Management (IAM)**
 - Fine-grained control over user and service permissions.
 - Supports policies, roles, groups, and multi-factor authentication (MFA).
- **Data Protection**
 - Encryption at rest: AWS Key Management Service (KMS), CloudHSM.
 - Encryption in transit: TLS/SSL, AWS Certificate Manager (ACM).
 - Automatic encryption options for S3, EBS, etc.
- **Network Security**
 - Virtual Private Cloud (VPC) with security groups, and private subnets.
 - AWS Shield and AWS WAF for DDoS and web application attack protection.
 - AWS Firewall Manager for centralized policy control.
- **Monitoring & Logging**
 - AWS CloudTrail for API call logging.
 - Amazon CloudWatch for monitoring metrics and events.
 - AWS GuardDuty for intelligent threat detection.
- **Application & Infrastructure Protection**
 - AWS Inspector for vulnerability assessment.
 - AWS Security Hub for centralized security posture visibility.
 - AWS Config for compliance auditing and configuration tracking.

AWS Security and Compliance



❖ Compliance in AWS

Compliance ensures that workloads meet legal, regulatory, and industry standards.

Global Compliance Programs Supported by AWS

AWS maintains certifications and attestations for multiple frameworks, including:

- **ISO 27001 / ISO 27017 / ISO 27018** (Information security and cloud privacy)
- **SOC 1, SOC 2, SOC 3** (Service Organization Control reports)
- **PCI DSS** (Payment Card Industry Data Security Standard)
- **HIPAA** (Health Insurance Portability and Accountability Act)
- **FedRAMP** (Federal Risk and Authorization Management Program)
- **GDPR** (General Data Protection Regulation) support tools

AWS Security and Compliance



❖ Compliance in AWS

AWS Compliance Tools

- **AWS Artifact** – On-demand access to AWS compliance reports and agreements.
- **AWS Audit Manager** – Automates evidence collection for audits.
- **AWS Config + AWS Security Hub** – Continuous compliance monitoring.
- **Well-Architected Framework – Security & Compliance Pillars** for best practices.

AWS Security and Compliance



❖ Benefits

AWS Compliance Tools

- **Security at Scale** – AWS's global infrastructure benefits from continuous investment in advanced security.
- **Regulatory Alignment** – Built-in support for many international compliance frameworks.
- **Customer Empowerment** – Tools to configure, monitor, and prove compliance with minimal overhead.

AWS Security and Compliance



❖ AWS Shared Responsibility Model

- The AWS Shared Responsibility Model divides security responsibilities between AWS and the customer, with AWS responsible for the "security of the cloud" (infrastructure) and the customer responsible for the "security in the cloud" (their data, applications, and configurations). This model means AWS secures the underlying hardware, software, and physical facilities, while customers are responsible for managing their guest operating system, applications, and security settings.

AWS's responsibilities (Security "of" the cloud)

- Protecting the global infrastructure that runs all AWS services.
- Maintaining the physical security of data centers.
- Managing the host operating system and virtualization layer.
- Providing security features like DDoS protection and the underlying network.

AWS Security and Compliance



❖ AWS Shared Responsibility Model

Customer's responsibilities (Security "in" the cloud)

- Managing the guest operating system, including updates and security patches.
- Securing their applications and data.
- Configuring security groups and network access controls.
- Managing user access, identity, and access management (IAM) policies.
- Ensuring compliance requirements for their specific data and applications are met.

AWS Security and Compliance



❖ AWS Shared Responsibility Model

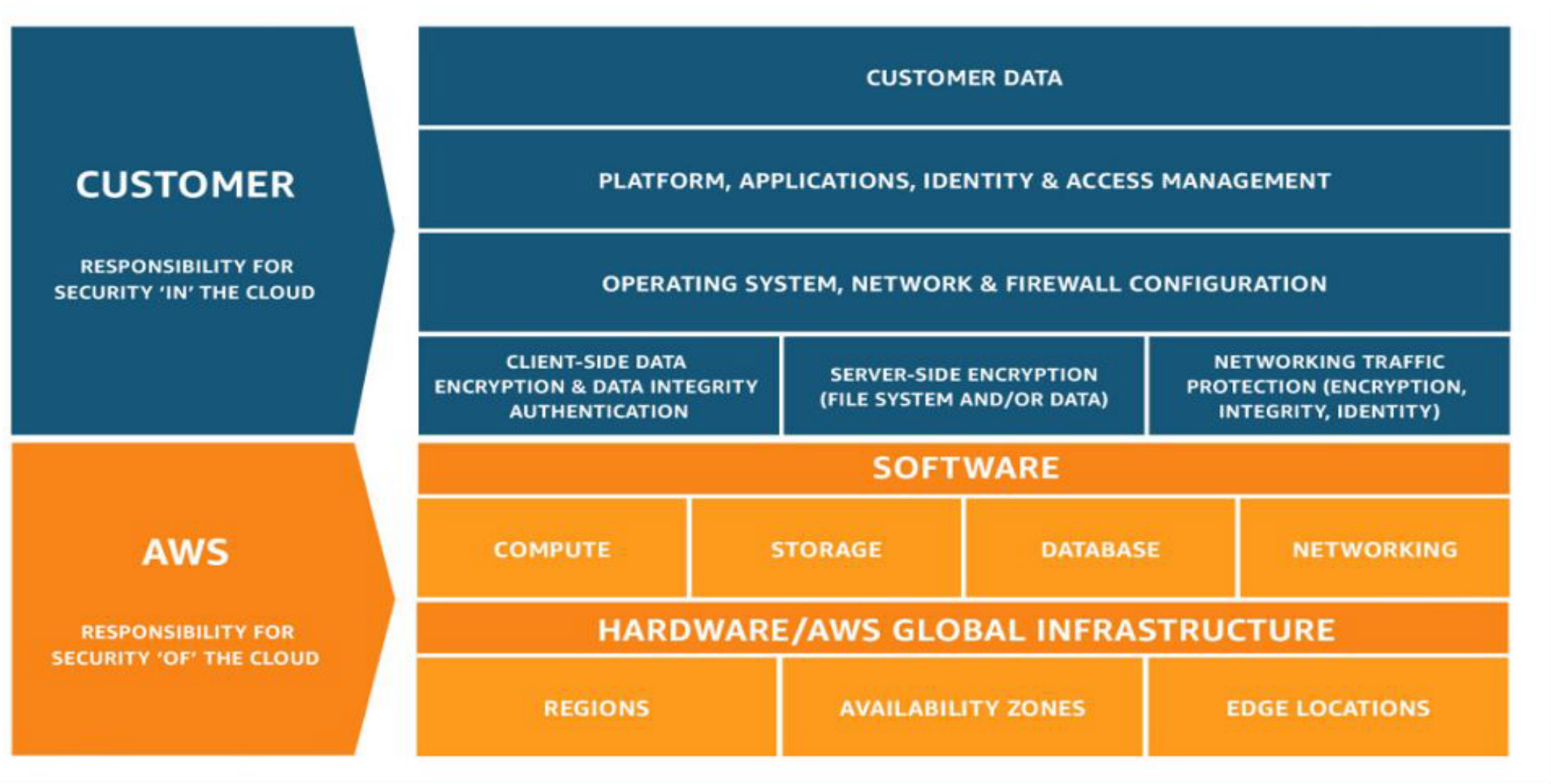
How responsibilities vary by service

- **Amazon EC2 (IaaS):** The customer is responsible for almost everything from the operating system upwards.
- **Amazon Relational Database Service(RDS) (PaaS):** AWS handles the OS and database engine patching, while the customer manages network access, database users, and permissions.
- **Amazon S3 (SaaS):** AWS manages the underlying infrastructure, but the customer is solely responsible for data access, encryption settings, and their data itself.

AWS Security and Compliance



❖ AWS Shared Responsibility Model



AWS Security and Compliance



❖ AWS Shared Responsibility Model

- The AWS Shared Responsibility Model is a security framework where AWS and its customers both have security duties. AWS is responsible for the security "of" the cloud, which includes the physical data centers, hardware, and networking that run its services. The customer is responsible for security "in" the cloud, which covers their data, applications, and operating systems, including configuring firewalls and managing user access.
- This customer/AWS shared responsibility model also extends to IT controls. Just as the responsibility to operate the IT environment is shared between AWS and its customers, so is the management, operation, and verification of IT controls shared.
- AWS can help relieve customer burden of operating controls by managing those controls associated with the physical infrastructure deployed in the AWS environment that may previously have been managed by the customer.
- As every customer is deployed differently in AWS, customers can take advantage of shifting management of certain IT controls to AWS, which results in a (new) distributed control environment. Customers can then use the AWS control and compliance documentation available to them to perform their control evaluation and verification procedures as required. The following are examples of controls that are managed by AWS, AWS customers, or both.

AWS Security and Compliance



❖ AWS Shared Responsibility Model

- The following are examples of controls that are managed by AWS, AWS customers, or both.
- **Inherited Controls** – Controls that a customer fully inherits from AWS.
- **Physical and Environmental controls**
- **Shared Controls** – Controls that apply to both the infrastructure layer and customer layers, but in separate contexts or perspectives. In a shared control, AWS provides the requirements for the infrastructure and the customer must provide their own control implementation within their use of AWS services.
- Examples include: Shared Controls are like the smoke detectors in your apartment.
- AWS's part: The building owner must ensure the smoke detector unit is installed correctly and the underlying building infrastructure supports fire safety.
- Your part: You need to make sure you don't block the smoke detector with paint or furniture, replace the batteries when needed, and train your family on what to do if it goes off.

AWS Security and Compliance



❖ AWS Key Management Service

- AWS Key Management Service (KMS) is a service that lets you create, manage, and control the encryption keys used to protect your data in AWS and in your applications.
- Think of it as a secure digital vault for your "passwords" (encryption keys) that can be used to lock and unlock your information.
- It handles the keys for you, integrating with other AWS services to easily encrypt data, while providing central control over who can use the keys and for what purpose.

Key purposes of KMS:

- Generate and store encryption keys.
- Manage key access permissions.
- Enable automatic key rotation.
- Integrate encryption with multiple AWS services.
- Maintain audit trails via AWS CloudTrail.

AWS Security and Compliance



❖ AWS Key Management Service

- To use KMS effectively, you need to understand a few core elements:

a) Customer Master Keys (CMKs) / KMS Keys

A Customer Master Key (CMK) in AWS is like a master key that locks and unlocks your data, ensuring it stays secret. It's the top-level key in a hierarchy, used to encrypt and decrypt other keys or data. You have control over CMKs, can manage who can use them, and can rotate them for added security, though AWS also offers simpler AWS-managed keys where AWS handles the management for you.

AWS Security and Compliance



❖ How Customer Master Keys (CMKs) / KMS Keys works?

1. **Encryption:** When you want to encrypt data, you can either use the CMK directly (for small amounts of data) or, more commonly, use it to create a separate, temporary data encryption key. This data key then encrypts your actual data.
2. **Decryption:** To decrypt the data, the process is reversed: the CMK is used to decrypt the data encryption key, which then decrypts your data.
3. **Key Security:** The CMK itself is protected by AWS and never leaves the service unencrypted. You use the AWS Key Management Service (KMS) to manage it, and its use is logged, giving you an audit trail.
4. **Control:** You have full control over customer-managed CMKs, allowing you to set policies on who can use the key and when.
5. **Key Rotation:** You can enable automatic key rotation, and AWS will manage the process of creating new key versions and re-encrypting data as needed without you having to manually intervene.
6. **Region-specific:** Each CMK is created within a specific AWS region, keeping the keys localized for compliance and security.

AWS Security and Compliance



❖ AWS Key Management Service

b) Envelope Encryption

Envelope encryption is like putting a document in a locked box (encrypting the data with a key) and then putting that box in a safe (encrypting the key with another master key). In AWS, this means using a unique Data Encryption Key (DEK) to encrypt your data, and then using a master key (like one from AWS KMS) to encrypt that DEK. The encrypted DEK is stored with the data, which is more efficient and secure than using a single key for everything.

How it works?

1. **Encrypt the data:** Your application uses a unique Data Encryption Key (DEK) to encrypt the actual data, like a large file.
2. **Encrypt the key:** That DEK is then encrypted by a master key, which is a key managed by AWS Key Management Service (KMS).
3. **Store the encrypted data:** The original data is now encrypted, and the DEK is encrypted by the master key. The encrypted DEK is stored alongside the encrypted data.
4. **Decryption:** To decrypt, the encrypted DEK is sent back to KMS. KMS uses the master key to decrypt the DEK, and then returns the original DEK to your application, which uses it to decrypt the data.

AWS Security and Compliance



❖ AWS Key Management Service

b) Envelope Encryption

Envelope encryption is like putting a document in a locked box (encrypting the data with a key) and then putting that box in a safe (encrypting the key with another master key). In AWS, this means using a unique Data Encryption Key (DEK) to encrypt your data, and then using a master key (like one from AWS KMS) to encrypt that DEK. The encrypted DEK is stored with the data, which is more efficient and secure than using a single key for everything.

How it works?

Store the encrypted data: The original data is now encrypted, and the DEK is encrypted by the master key. The encrypted DEK is stored alongside the encrypted data.

Decryption: To decrypt, the encrypted DEK is sent back to KMS. KMS uses the master key to decrypt the DEK, and then returns the original DEK to your application, which uses it to decrypt the data.

AWS Security and Compliance



❖ AWS Key Management Service

c) Key Policies & IAM Policies

- In AWS, an IAM policy is a master-level rule that controls a user's, group's, or role's permissions across various services, while a Key policy is a more specific, resource-level policy that controls who can use a particular AWS KMS key (for encryption/decryption) and how.
- You can think of an IAM policy as the general ID card for a user, dictating what doors they can open in the entire building, whereas a Key policy is like a specific key to a special vault, and it must explicitly grant access to the user before the user's general ID card (IAM policy) can even be checked for that vault.

d) Key Types

- **Symmetric keys** – single key for both encryption and decryption.
- **Asymmetric keys** – public/private key pairs for signing, verification, or encryption.

AWS Security and Compliance



❖ AWS Key Management Service

- **Types of KMS Keys**

1. Customer-managed CMK: These are keys you create, own, and fully control. You decide who can use them, how often they rotate, and when they are deleted. Think of it like owning the key to your own house.

2. AWS-managed CMK: These keys are created and managed by AWS services on your behalf. You can see them and track their use, but you don't have direct control over their management or permissions. This is like a key provided by a landlord for a rental property – you can use it, but the landlord manages its existence.

3. AWS-owned CMK: These are keys completely owned and managed by AWS for their own services. You don't see or interact with these keys directly; they are used internally by AWS to encrypt data within their systems. This is like the master key to the entire building, held only by the building management.

AWS Security and Compliance



❖ AWS Key Management Service

● 4. Integration with AWS Services

Integration with AWS Services is like giving different apps and programs built-in tools to talk to each other smoothly, without you having to write a lot of custom code to make them work together. It uses specialized services to handle the communication, so one part of your application can trigger another part to do something, and they can do it reliably, even if one part has an issue

- **Amazon S3** – Encrypt objects at rest (SSE-KMS).
- **Amazon EBS** – Encrypt volumes and snapshots.
- **Amazon RDS** – Encrypt database instances.
- **AWS Lambda** – Secure environment variables.
- **Amazon DynamoDB** – Encrypt table data.

AWS Security and Compliance



❖ AWS Key Management Service

- **5. Security and Compliance**

Security is about protecting your things (like data, computers, and assets) from harm, while compliance is about following the rules and laws that have been set for you. Security is an ongoing, proactive effort to prevent threats, whereas compliance is a more specific process of proving you meet external requirements or standards, like those from governments or industry bodies.

AWS Security and Compliance



❖ AWS Key Management Service

6. Key Rotation

- Key rotation in AWS is the practice of periodically changing cryptographic keys to improve security by limiting the exposure of any single key. This is most commonly done in AWS Key Management Service (KMS), where a key's underlying material is updated while the key ID remains the same, ensuring that data encrypted with older versions of the key can still be decrypted. AWS provides both automatic and manual options for key rotation.

7. Pricing

You pay for:

- Number of **KMS keys** you create and store.
- Number of **API requests** (Encrypt, Decrypt, GenerateDataKey, etc.).

AWS Security and Compliance



❖ AWS Key Management Service

8. Benefits

- Centralized key management.
- Fine-grained access control.
- Easy integration with AWS ecosystem.
- Compliance-ready audit trails.
- Scalability for millions of encryption operations.

AWS Security and Compliance



◆ AWS Web Application Firewall

- **AWS Web Application Firewall (WAF)** is a fully managed service by AWS that protects your web applications from bad traffic and malicious threats. It integrates with many AWS services including **Amazon CloudFront, Application Load Balancer (ALB), API Gateway and AWS App Runner**.
- AWS WAF works by allowing you to **create security rules that inspect incoming HTTP(S) requests**. These rules can detect and block bad traffic so only valid requests get to your application. The firewall evaluates each request based on the criteria you set, such as the request's IP address, geographic location, query strings and HTTP headers. If a request matches any of your rules, AWS WAF takes the action you specified – block, allow or count the request.

AWS Security and Compliance



◆ Key Features of AWS WAF

- AWS WAF comes with several features that make it a reliable and scalable solution for web application security:

1. Customizable Rules

- AWS WAF allows you to create custom security rules tailored to your application's specific needs. You can set conditions based on various factors, such as IP addresses, HTTP headers, or geographical location. This customization helps ensure that only legitimate traffic reaches your application, while harmful requests are blocked.

2. Managed Rule Groups

- For a faster setup, AWS WAF provides pre-configured managed rule groups that protect against common threats like **SQL injection**, cross-site scripting (XSS), and malicious **IP addresses**. These rules are regularly updated to stay ahead of emerging security risks, making it easy for you to get started with minimal configuration.

AWS Security and Compliance



❖ Key Features of AWS WAF

- **3. Real-Time Monitoring and Logging**

- AWS WAF provides real-time monitoring and logging of web traffic. With AWS WAF Logs, you can track detailed information about each request, including which rules were triggered and what actions were taken. This visibility helps you analyze traffic patterns, troubleshoot issues, and fine-tune your security settings over time.

- **4. DDoS Protection**

- AWS WAF integrates with AWS Shield, offering automatic protection against **Distributed Denial of Service (DDoS) attacks**. This integration ensures your application remains available and responsive, even during large-scale attack attempts.

- **5. Cost-Effective and Scalable**

- AWS WAF operates on a pay-as-you-go pricing model, meaning you only pay for the rules you create and the volume of web requests your application receives. As your application grows, AWS WAF scales automatically to handle increased traffic, ensuring continued protection without added complexity.

AWS Security and Compliance



❖ Benefits of AWS WAF

- **Comprehensive Security:** AWS WAF provides strong protection against common web threats such as SQL injection and cross-site scripting (XSS), ensuring your application remains secure from these types of attacks.
- **Customizable Rules:** You have the flexibility to create security rules tailored to your specific requirements, enabling you to filter traffic based on IP addresses, headers, or other criteria.
- **Pre-Configured Managed Rules:** AWS offers a collection of pre-built rules that are frequently updated to guard against known vulnerabilities, so you don't need to worry about manual updates.
- **Scalable:** As your traffic increases, AWS WAF effortlessly scales to accommodate the higher volume, making it an excellent choice for businesses of all sizes.

AWS Security and Compliance



❖ Benefits of AWS WAF

- **Cost-Effective:** With a pay-as-you-go pricing structure, you only pay for what you use, making it a budget-friendly option for businesses at different growth stages.
- **Real-Time Insights:** AWS WAF integrates with [CloudWatch](#), providing you with detailed logs and analytics. This feature allows you to monitor and respond to security threats as they happen.
- **DDoS Protection:** AWS WAF collaborates with AWS Shield to automatically protect against DDoS attacks, adding an extra layer of security.
- **Seamless Integration with AWS:** It works smoothly with other AWS services like [CloudFront](#), [Elastic Load Balancing](#) (ELB), and API Gateway, simplifying deployment and enhancing efficiency.

AWS Security and Compliance



❖ Limitations of AWS WAF

- **Complex Setup:** Setting up custom rules and navigating the security options can be challenging, particularly for users who aren't familiar with AWS or web security.
- **Focus on Layer 7:** AWS WAF is primarily designed to protect at the application layer (Layer 7). It doesn't offer deep protection at lower network layers, so it may not address all types of network-level attacks.
- **Ongoing Management:** Custom rules require regular updates to stay effective, which means continuous attention and effort from your team.
- **Can Get Expensive:** For applications with high traffic, the pay-as-you-go pricing model can lead to escalating costs as your traffic increases.

AWS Security and Compliance



❖ Limitations of AWS WAF

- **Learning Curve:** New users may find the AWS Console and setup process overwhelming if they aren't already familiar with the platform.
- **Limited Flexibility with Managed Rules:** While AWS offers managed rules, your control over fine-tuning them to your specific needs is somewhat limited.
- **Potential Latency:** A large number of rules or managing high traffic volumes can introduce slight delays in processing requests, potentially affecting performance.
- **AWS-Specific:** AWS WAF is designed primarily for use with AWS services, making it less ideal for protecting infrastructure that isn't hosted on AWS.

AWS Security and Compliance



❖ AWS WAF Pricing Breakdown

AWS WAF operates on a **pay-as-you-go pricing model**, making it cost-effective for businesses of all sizes. The main factors influencing the pricing are:

1. Web ACL

AWS charges **\$5 per month** for each Web Access Control List (Web ACL) you create.

2. Rules

You will be charged **\$1 per month** for each rule you configure for your Web ACL.

3. Requests

AWS WAF charges **\$0.60 per million requests** processed.

4. Managed Rule Groups

Managed rules come with additional costs. You pay based on the number of rules and the traffic volume. These costs vary depending on the selected rule group.

AWS Security and Compliance



❖ AWS WAF Cost Example:

Web ACL: \$5 per month

- **Rules:** \$1 per month per rule
- **Requests:** \$0.60 per million requests
- **Managed Rules:** Varies based on usage

AWS Security and Compliance



❖ AWS Shield

- AWS Shield is Amazon's service that protects your applications on AWS from Distributed Denial of Service (DDoS) attacks, which are malicious attempts to flood a network with traffic and make it unavailable to legitimate users.
- It works by using automatic detection and mitigation to defend against these attacks, ensuring your services stay online and perform well. There are two versions: a free, automatically-enabled version (Standard) and a paid, more advanced version (Advanced).

AWS Security and Compliance



❖ AWS Security Best Practices

1. Identity and Access Management (IAM)

AWS security starts with strong identity control.

- **Principle of Least Privilege (PoLP)** – Give users, roles, and applications *only* the permissions they need.
- **Use IAM Roles over Access Keys** – Avoid long-term credentials; use temporary security credentials via roles (e.g., EC2 roles, Lambda roles).
- **Multi-Factor Authentication (MFA)** – Enforce MFA for privileged accounts, especially the root account.
- **IAM Policies** – Prefer **managed policies** for common needs, and use inline or customer-managed policies for fine-grained control.
- **Avoid Root Account for Daily Operations** – Use it only for initial setup and emergencies.

AWS Security and Compliance



❖ AWS Security Best Practices

2. Data Protection

Protecting data in transit and at rest is critical.

- **Encryption at Rest** – Enable **AWS Key Management Service (KMS)** for services like S3, RDS, EBS.
- **Encryption in Transit** – Use **TLS/SSL** for API and application communication.
- **Customer-Managed Keys (CMKs)** – Use your own KMS keys when you need tighter control and auditing.
- **S3 Bucket Security** –
 - Enable **Block Public Access**.
 - Use **bucket policies** to restrict access to trusted sources.
 - Enable **S3 Object Lock** for write-once-read-many (WORM) protection.

AWS Security and Compliance



❖ AWS Security Best Practices

3. Network Security

Isolate and control traffic flow.

- **VPC Design** –
 - Use **private subnets** for backend services.
 - Restrict outbound access using **NAT gateways** or **VPC endpoints**.
- **Security Groups & NACLs** –
 - Deny by default, allow only required inbound/outbound traffic.
 - Use least privilege for ports (e.g., restrict SSH to admin IPs).
- **DDoS Protection** – Use **AWS Shield Standard** (free) or **AWS Shield Advanced** for critical workloads.
- **Web Application Firewall (WAF)** – Protect against common attacks (SQL injection, XSS).

AWS Security and Compliance



❖ AWS Security Best Practices

4. Monitoring & Logging

Continuous monitoring detects suspicious activity early.

- **AWS CloudTrail** –
 - Enable in all regions.
 - Send logs to an S3 bucket with MFA delete enabled.
- **Amazon CloudWatch** –
 - Set up alarms for unusual patterns (e.g., high network usage, failed login attempts).
- **VPC Flow Logs** – Capture IP traffic for analysis and threat detection.
- **AWS Config** – Track configuration changes for compliance audits.

AWS Security and Compliance



❖ AWS Security Best Practices

5. Application Security

Integrate security at the code and deployment level.

- **Code Scanning** – Use **Amazon CodeGuru** or third-party tools to detect vulnerabilities.
- **Secrets Management** – Store API keys and credentials in **AWS Secrets Manager** or **Systems Manager Parameter Store**, never in code.
- **Least-Privilege Lambda Functions** – Assign functions only the permissions they require.

6. Backup & Disaster Recovery

Data loss prevention is a key security layer.

- **Automated Backups** – Enable automatic backups for RDS, DynamoDB, EBS.
- **Cross-Region Backups** – Store backups in a different region for disaster recovery.
- **Versioning & Replication** – Use **S3 versioning** and **Cross-Region Replication (CRR)**.

AWS Security and Compliance



❖ AWS Security Best Practices

7. Compliance & Governance

Ensure you meet industry standards and regulations.

- **AWS Artifact** – Access compliance reports (e.g., ISO 27001, SOC 2).
- **Service Control Policies (SCPs)** – Apply organization-wide permission boundaries in AWS Organizations.
- **AWS Security Hub** – Centralized security posture management.

8. Incident Response

Be ready to act quickly if a breach occurs.

- **Predefine Incident Response Playbooks** – Automate responses using **AWS Lambda** and **CloudWatch Events**.
- **Isolate Compromised Resources** – Move them to a quarantine security group.
- **Forensics** – Use Amazon Detective to investigate.

AWS Security and Compliance



❖ AWS Security Best Practices

7. Compliance & Governance

Ensure you meet industry standards and regulations.

- **AWS Artifact** – Access compliance reports (e.g., ISO 27001, SOC 2).
- **Service Control Policies (SCPs)** – Apply organization-wide permission boundaries in AWS Organizations.
- **AWS Security Hub** – Centralized security posture management.

8. Incident Response

Be ready to act quickly if a breach occurs.

- **Predefine Incident Response Playbooks** – Automate responses using **AWS Lambda** and **CloudWatch Events**.
- **Isolate Compromised Resources** – Move them to a quarantine security group.
- **Forensics** – Use Amazon Detective to investigate.